soken

Solana program security review

DREMT

Commit `bdc99fb889b6`, Solana mainnet

2 November 2026

0	0	3	6	6
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL

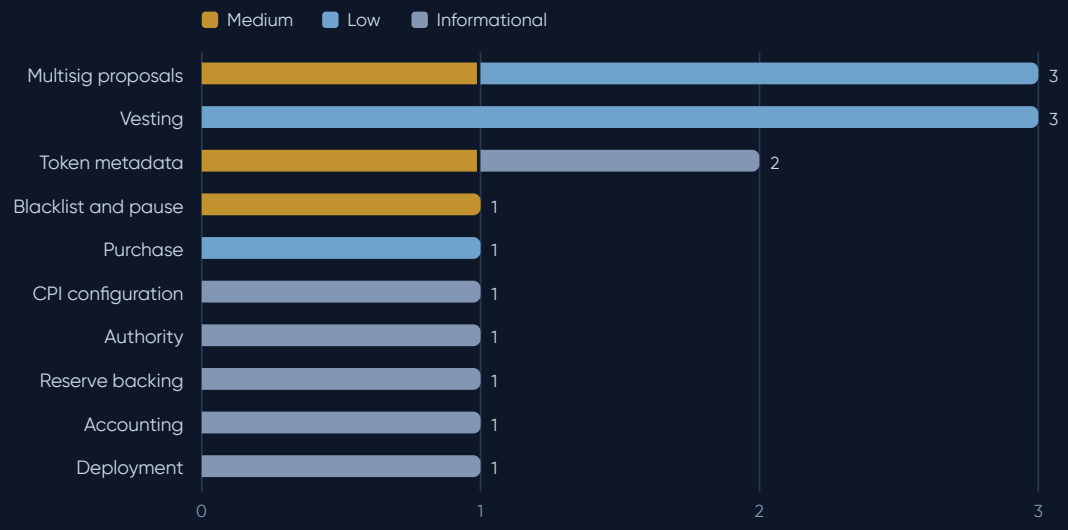
PREPARED BY SOKEN LTD	CLIENT DREMT, dremt.io
REPOSITORY AND COMMIT Source archive from the client, `programs/dremt/src`, bdc99fb889b6	NETWORK Solana mainnet
SCOPE One Anchor program, `dremt`, five source files: the token program behind the DREMT Token-2022 mint	FINDINGS 0 Critical, 0 High, 3 Medium, 6 Low, 6 Informational
PROGRAM `4iwHwvSXrdpgsVPhrM4XDB9Lh7s284MJFJToeS9N8GJh`	DATE 2 November 2026

01 Summary

0	0	3	6	6
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL

1 PROGRAM IN SCOPE, LIVE ON MAINNET	**3,948** SOURCE LINES IN SCOPE	**34** INSTRUCTIONS REVIEWED
111 / 111 CLIENT UNIT TESTS PASSED	**34 / 34** INSTRUCTION NAMES OF THE SOURCE FOUND IN THE MAINNET BINARY	**3 of 5** MULTISIG BEHIND EVERY PRIVILEGED ACTION EXCEPT METADATA

Figure 1. Findings by component



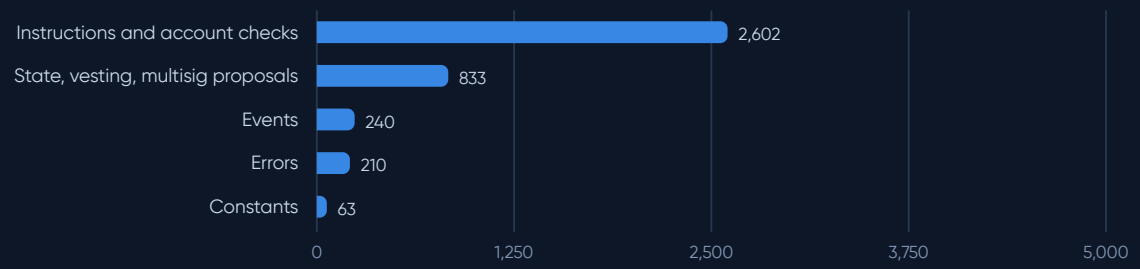
ID	TITLE	COMPONENT	SEVERITY
M-01	Blacklist and pause do not apply to DREMT transfers	Blacklist and pause	MEDIUM
M-02	One multisig owner alone can change the token name, symbol and URI	Token metadata	MEDIUM
M-03	The USDC refund of an admin burn goes to whichever owner executes it	Multisig proposals	MEDIUM
L-01	With the mainnet vesting config a vesting pause cannot be resumed	Vesting	LOW
L-02	Resuming vesting resets the limit of three pauses per 30 days	Vesting	LOW
L-03	The lifetime limit of 1,000,000 USDC per buyer is per address	Purchase	LOW
L-04	The vesting config accepts a one-second cooldown and pause length	Vesting	LOW
L-05	Configuration proposals execute while the program is paused	Multisig proposals	LOW

L-06	An admin burn built from the program interface fails	Multisig proposals	LOW
I-01	The CPI flag and the program allow list have no effect on chain	CPI configuration	INFORMATIONAL
I-02	Direct `set_purchase_fee` and `transfer_authority` cannot be signed	Authority	INFORMATIONAL
I-03	`update_reserve_value` cannot succeed	Reserve backing	INFORMATIONAL
I-04	Metadata decimals argument and URI	Token metadata	INFORMATIONAL
I-05	Burn counter and internal supply differ from the chain	Accounting	INFORMATIONAL
I-06	The mainnet binary is not a reproducible build	Deployment	INFORMATIONAL

02 Scope

COMPONENT	FILE, RELATIVE TO PROGRAMS/DREMT/SRC	SLOC	NOTE
Instructions and account checks	`lib.rs`	2,602	34 instructions, account structs, helpers
State, vesting, multisig proposals	`state.rs`	833	863 further lines of unit tests not counted
Events	`events.rs`	240	Event structs
Errors	`error.rs`	210	103 error codes
Constants	`constants.rs`	63	Price, limits, seeds
Total		**3,948**	

Figure 2. Size of the code in scope, source lines without comments and blank lines

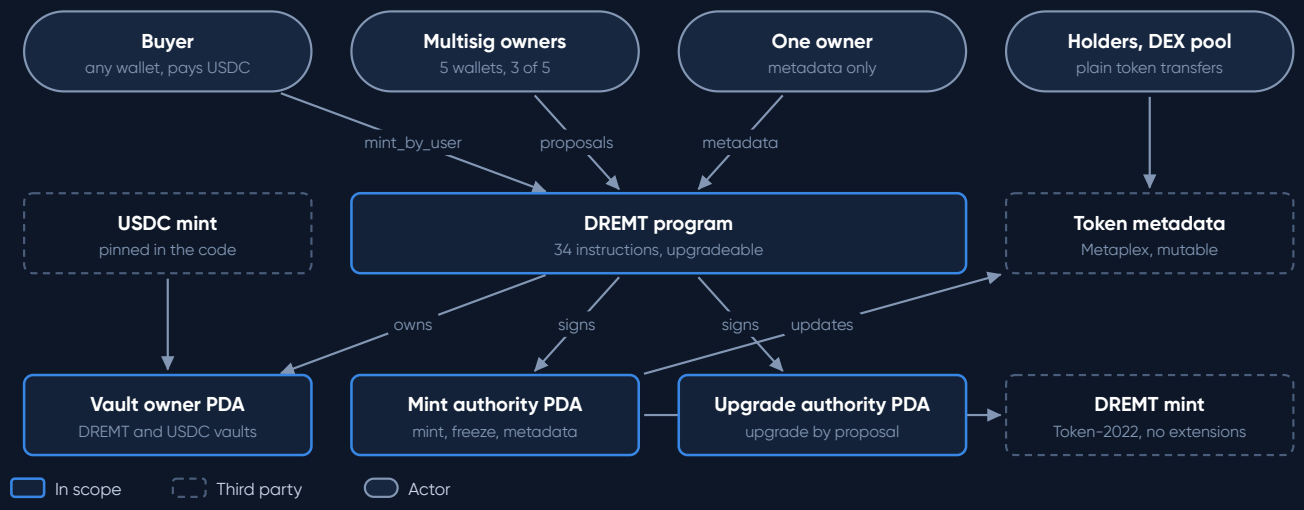


Out of scope

ITEM	REASON
DREMT ETF program	Separate program, separate review
Backend API, wallet app, web frontend	Off-chain components, separate review
Metaplex Token Metadata, SPL Token, Token-2022, USDC	External programs, used as deployed
Raydium pool and market making	Market venue, not part of the program
Physical reserves behind the token	Not verifiable from the code or the chain

03 Architecture and privileged roles

Figure 3. DREMT token program: actors, program accounts and external programs



Privileged roles

ROLE	HOLDER, READ ON CHAIN 2 NOVEMBER 2026	TYPE	POWERS
Upgrade authority	`DiRfgcJivBsawk11SDD1YpUcqW7YAT8Ai7YbxB6osTVd`	Program PDA, seed `upgrade_authority`	Replace the program code, only through `execute_upgrade_proposal` after 3 of 5 approvals
Multisig	`5D2kznd22qoYNnaFxCxPvaTfHMAfQ8YTjdA1iGCSpHVz`	SPL Token multisig, 3 of 5, signer set fixed at creation	Source of every proposal approval; also stored as `token_state.authority`
Multisig owners	`Bj4ThGugXDqHSHUmJiGDhe7HXxcaDxfz3FRAqBgHqfnk`, `4Wn8jjHMEev8YG5JeymLXKbCyCEYNyaS6tLCqDBgLNri`, `FHrsQQxTWjNnCbvyaLZ14KKT7C9eZbwwKascouuEZgw9`, `Ggz322dPoqeKd9JrcCUK6Fv6Qc5BeJWphVsUJDozkB9Y`, `4QZmHoR8dYQiPeDd8LiF9ymBGWpcQhxqCwdYLpv8KPU6`	Single wallets	Create, approve and execute proposals; each one alone can create or update the token metadata, see M-02
Mint authority	`E5rNU7YXJCzyEcWZFKANUV9Uf29GujNgjNdnEtdwu6m`	Program PDA	Mint and freeze authority of the DREMT mint, update authority of the metadata. The program mints through `mint_by_user`; no instruction freezes an account, see M-01
Vault owner	`EYTGC7oB6n4WrPsnzQfX5E1UxPGWLjJx5j716GxPo95x`	Program PDA	Owns the DREMT vault and the USDC vault; releases vested tokens and burn refunds after 3 of 5 approvals
Fee recipient	`4R6RT1m5C8b5XgpeJMY4pcHtFxmdQrirGRVSJoVCZdZb`	Wallet	Receives the purchase fee; the fee is 0 bps
Buyer	Any wallet not on the blacklist	Any wallet	Buys DREMT at 0.80 USDC with `mint_by_user`; pays for goods with `purchase_item`

PROGRAM STATE ON MAINNET, READ ON 2 NOVEMBER 2026

ITEM	VALUE
DREMT mint	`AmUYmDAhxoD841aT44dNLVHRvnZ1zGe1uppZLFw5MSou`, Token-2022, 82-byte account (no extensions), 6 decimals
Mint supply	10,002,384.876703 DREMT
`token_state.total_supply`	10,002,384.906089 DREMT, 0.029386 above the mint supply
`token_state.max_supply`	100,000,000,000 DREMT
Paused	No. `cpi_enabled` false, authorized programs none, purchase fee 0 bps
Vesting config	`emergency_pause_cooldown` 0, `max_pause_duration` 0, see L-01
Proposals	5 proposal accounts, all executed with 3 approvals on 24 February 2026: 3 program upgrades, 2 vested releases (9,375 DREMT dex_liquidity, 3,000 DREMT market_making). Next id 6
Blacklist	0 of 300 entries
DREMT vault `DYSuvbzcD9kizqveKfvM9NeSyS96nSSzBmXprWHcRSSS`	9,987,625 DREMT
Buyers	27 purchase tracker accounts, one per buying address
USDC vault `3SL9pgmSgAuGvN6gwRsfzyVNF1BbKUwaby9hc6quBnGq`	1,907.924878 USDC
Last operation	28 October 2026, 67 operations counted by the program

TOKEN DISTRIBUTION ACCOUNT, READ ON 2 NOVEMBER 2026

CATEGORY	ALLOCATION	RELEASED	TGE	CLIFF, DAYS	VESTING, DAYS
reserve_treasury	6,000,000	0	5%	30	365
marketing_community	2,500,000	0	5%	30	365
dex_liquidity	600,000	9,375	100%	0	60 seconds
advisors	500,000	0	2%	90	548
market_making	400,000	3,000	100%	0	60 seconds
Total	10,000,000	12,375			

Vesting starts on 24 February 2026. 10,000,000 minus the 12,375 released equals 9,987,625, the balance of the DREMT vault.

PRIVILEGED ACTIONS ON MAINNET SINCE DEPLOYMENT

INSTRUCTION	COUNT	DATES
`initialize`, `migrate_token_state`, `initialize_token_distribution`	3	18 and 24 February 2026
`transfer_authority`	3	18 to 24 February 2026
`execute_upgrade_proposal`	3	24 February 2026
`execute_claim_vested_proposal`	2	24 February 2026
`create_token_metadata`	1	24 February 2026
`update_token_metadata`	3	28 February, 4 March 2026
`mint_by_user`	62	24 February to 28 October 2026

04 Method and severity scale

STEP	WORK DONE
Manual review	Line-by-line reading of the five source files: every instruction, its account constraints, the proposal life cycle, vesting arithmetic and the token transfers
Source identity	sha256 over `constants.rs`, `error.rs`, `events.rs`, `lib.rs`, `state.rs` in this order: `bdc99fb889b6...b90aa`. `lib.rs` is dated 24 February 2026, the day of the last mainnet deploy
Deployment comparison	Program dumped from mainnet; instruction names and error texts of the source searched in the binary; upgrade authority derived from the seeds
On-chain state	Program accounts decoded with the program interface; mint, metadata, multisig, vaults and the full transaction history of the state account read from mainnet
Fork demonstration	Local validator with the mainnet binary and mainnet accounts; 3 of 5 proposals signed by test keys put in place of the multisig signers. M-01, M-03 and L-06 shown with real transactions
Client tests	Unit tests of the program crate
Static checks	`cargo audit` over 275 dependencies
Severity	Each finding rated by what an actor can do on mainnet with the roles and the state read on the report date

Severity scale

SEVERITY	MEANING
CRITICAL	Loss or permanent freeze of user funds with no unusual precondition
HIGH	Loss or freeze under realistic preconditions
MEDIUM	Limited loss, a control that does not work as documented, or loss that needs an uncommon but plausible condition
LOW	No direct loss in normal operation; a disclosed or governance-triggered risk
INFORMATIONAL	Code quality, documentation and process

05 Findings

Medium

M-01 Blacklist and pause do not apply to DREMT transfers

MEDIUM

COMPONENT	LOCATION	CATEGORY
Blacklist and pause	`lib.rs:2132–2168` (`on_transfer_hook`), comment at `lib.rs:2139`	Control not enforced

DESCRIPTION

`on_transfer_hook` rejects a transfer when the program is paused or when the sender or the receiver is on the blacklist. Token-2022 calls a transfer hook only for a mint created with the TransferHook extension. The DREMT mint on mainnet is an 82-byte account, the size of a mint with no extension, so no transfer calls the hook. The comment at `lib.rs:2139` states that the mint is configured with the hook extension; the chain shows otherwise.

CONTROL	WHERE IT APPLIES ON MAINNET	WHERE IT DOES NOT APPLY
Blacklist	`mint_by_user`, `purchase_item`	Wallet to wallet transfers, DEX trades, exchange deposits and withdrawals
Pause	Program instructions with a pause check	Every transfer of DREMT
Freeze authority	Held by the mint authority PDA	No instruction of the program calls `FreezeAccount`; a frozen account needs a program upgrade first

DEMONSTRATION

Local validator loaded with the program binary dumped from mainnet and the mainnet accounts; the multisig signer list and the owner of one holder account replaced with test keys.

STEP	RESULT ON THE FORK
3 of 5 proposal adds the holder to the blacklist	Executed; blacklist holds the address
Blacklisted holder transfers 100 DREMT to another wallet with Token-2022 `transferChecked`	Succeeds; 908.223199 to 808.223199, receiver 0 to 100
Same holder calls `mint_by_user`	Rejected with `AddressBlacklisted`
3 of 5 proposal pauses the program; `is_paused` true; a holder transfers 10 DREMT	Succeeds

IMPACT

A blacklisted address keeps full use of its DREMT outside the program. A pause stops buying through the program but not the secondary market. Integrators that rely on the documented blacklist get no protection from it.

RECOMMENDATION

Either state in the documentation that the blacklist and the pause cover only program instructions, or add a freeze and thaw instruction behind a 3 of 5 proposal that uses the existing freeze authority. A transfer hook needs a new mint with the extension.

M-02 One multisig owner alone can change the token name, symbol and URI

MEDIUM

COMPONENT	LOCATION	CATEGORY
Token metadata	`lib.rs:1947–2010` (`create_token_metadata`), `lib.rs:2014–2083` (`update_token_metadata`)	Single-signer privilege

DESCRIPTION

Both instructions check that the signer is one of the five owners of the multisig and then sign the Metaplex call with the mint authority PDA. They do not go through a proposal, so the 3 of 5 threshold does not apply. The metadata on mainnet is mutable and its update authority is the mint authority PDA.

DATE	INSTRUCTION	SIGNER
24 February 2026	`create_token_metadata`	1 owner, `Bj4ThGugXDqHSHUmJiGDhe7HXxcaDxfz3FRAqBgHqfnk`
28 February 2026	`update_token_metadata`	1 owner, `Bj4ThGugXDqHSHUmJiGDhe7HXxcaDxfz3FRAqBgHqfnk`
4 March 2026	`update_token_metadata`, twice	1 owner, `Bj4ThGugXDqHSHUmJiGDhe7HXxcaDxfz3FRAqBgHqfnk`

IMPACT

A single compromised owner key can rename the token or point its URI to other content in wallets and explorers. No funds move, but holders and exchanges read the name and the logo from this account.

RECOMMENDATION

Add a metadata action to the proposal types and remove the direct path, or lock the metadata after the final update with a proposal.

M-03 The USDC refund of an admin burn goes to whichever owner executes it

MEDIUM

COMPONENT	LOCATION	CATEGORY
Multisig proposals	`lib.rs:1086–1247` (`execute_admin_burn_proposal`), `lib.rs:3572–3576`, `state.rs:22`	Payout destination

DESCRIPTION

The approved action `AdminBurnWithVesting` holds only `amount` and `category`. On execution the program burns the tokens and pays `amount` times 0.80 USDC from the USDC vault to `executor_refund_account`, which must belong to the executor. The three approvers do not choose the recipient of the refund.

ITEM	VALUE
Refund per burned DREMT	0.80 USDC
USDC vault on 2 November 2026	1,907.924878 USDC
Largest refund possible today	1,907.924878 USDC, the check `usdc_vault.amount >= refund_amount` limits it

DEMONSTRATION

Local validator loaded with the program binary dumped from mainnet and the mainnet accounts; the multisig signer list and the owner of one holder account replaced with test keys.

STEP	RESULT ON THE FORK
Owners 1, 2 and 3 approve a burn of 100 DREMT from `dex_liquidity`	Proposal holds 3 approvals
Owner 4, not an approver, executes it with its own USDC account	Succeeds when the mint is passed writable, see L-06
Balances	USDC vault 1,907.924878 to 1,827.924878; owner 4 USDC 0 to 80; DREMT vault 9,987,625 to 9,987,525; mint supply minus 100

IMPACT

After an approved burn, any one of the five owners can execute it first and receive the USDC of the vault in a personal account.

RECOMMENDATION

Add the refund recipient to `AdminBurnWithVesting` and check the refund account against it at execution.

Low

L-01 With the mainnet vesting config a vesting pause cannot be resumed

LOW

COMPONENT	LOCATION	CATEGORY
Vesting	`state.rs:1092–1138` (`resume_vesting`), `lib.rs:1029` (`execute_resume_vesting_proposal`)	Configuration

DESCRIPTION

`resume_vesting` requires a pause of at least 3,600 seconds and at most twice `max_pause_duration`. On mainnet `max_pause_duration` is 0, so the second condition fails for every pause. While vesting is paused, `execute_claim_vested_proposal` and `execute_admin_burn_proposal` stop with `VestingPaused`.

CONDITION	MAINNET VALUE	RESULT
Pause length at least `MIN_PAUSE_DURATION`	3,600 s	Met after one hour
Pause length at most 2 x `max_pause_duration`	0 s	Never met

IMPACT

After an emergency pause, no vested tokens can be released until a further proposal sets `max_pause_duration`. The same lock occurs with any config when a pause outlasts twice `max_pause_duration`.

Demonstrated by the unit test `soken_l01_resume_fails_with_mainnet_config`.

RECOMMENDATION

Set the vesting config by proposal now. Drop the upper bound in `resume_vesting` or replace it with a warning event.

L-02 Resuming vesting resets the limit of three pauses per 30 days

LOW

COMPONENT	LOCATION	CATEGORY
Vesting	`state.rs:1134–1136`	Rate limit

DESCRIPTION

`emergency_pause_vesting` allows three pauses per 30-day period. `resume_vesting` sets `pause_count_in_period` to 0 and starts a new period, so pause and resume can repeat with only the cooldown in between.

Demonstrated by the unit test `soken_l02_resume_resets_pause_counter`: six pauses inside one 30-day period.

RECOMMENDATION

Reset the counter only when the 30-day period ends, inside `emergency_pause_vesting`.

L-03 The lifetime limit of 1,000,000 USDC per buyer is per address

LOW

COMPONENT	LOCATION	CATEGORY
Purchase	`lib.rs:2771–2778`, `state.rs:537–568`, `constants.rs:64`	Limit design

The purchase tracker is seeded by the buyer address. A buyer with several addresses gets a fresh limit for each. The limit of 250,000 USDC per transaction applies as written.

RECOMMENDATION

Describe the limit as per address in the documentation, or bind it to an identity attestation if a per-person limit is intended.

L-04 The vesting config accepts a one-second cooldown and pause length

LOW

COMPONENT	LOCATION	CATEGORY
Vesting	`lib.rs:1281–1282` (`execute_update_vesting_config_proposal`)	Input bounds

The proposal checks only that `emergency_pause_cooldown` and `max_pause_duration` are above 0. A value of 1 second removes the cooldown and, together with L-01, makes any resume impossible.

RECOMMENDATION

Require at least `MIN_PAUSE_DURATION` for the cooldown and at least one day for `max_pause_duration`.

L-05 Configuration proposals execute while the program is paused

LOW

COMPONENT	LOCATION	CATEGORY
Multisig proposals	`lib.rs` account structs of the `execute_*_proposal` instructions	Pause consistency

PROPOSAL EXECUTED DURING A PAUSE	PAUSE CHECK
Blacklist add and remove, authorize and revoke program, set CPI flag, vesting config, purchase fee, program upgrade	None
Admin burn, claim vested, transfer authority, update max supply	Yes

RECOMMENDATION

Record which proposals are meant to work during a pause and add the check to the others.

L-06 An admin burn built from the program interface fails

LOW

COMPONENT	LOCATION	CATEGORY
Multisig proposals	`lib.rs:3546–3549` (`ExecuteAdminBurnProposal.mint`)	Account mutability

DESCRIPTION

`execute_admin_burn_proposal` burns DREMT, which changes the supply stored in the mint account, but the account struct declares `mint` without `mut`. The program interface therefore marks the mint read-only, and a transaction built from it fails inside the burn call.

TRANSACTION ON THE FORK	RESULT
Accounts as in the program interface	Fails: `Cross-program invocation with unauthorized signer or writable account`
Same proposal, mint marked writable by hand	Succeeds

RECOMMENDATION

Declare the mint `mut` in `ExecuteAdminBurnProposal`, or document that clients must pass it writable.

Informational

I-01 The CPI flag and the program allow list have no effect on chain

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
CPI configuration	`lib.rs:2418–2470` (`mod cpi`), `lib.rs:808`, `:864`, `:920`, `state.rs:442`	Dead configuration

`cpi_enabled` and `authorized_programs` are read only in `cpi::purchase_item`, a helper outside the `#[program]` module that runs in a calling program. The on-chain `purchase_item` and `mint_by_user` do not read them. The three proposals that set them change stored data only.

I-02 Direct `set_purchase_fee` and `transfer_authority` cannot be signed

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Authority	`lib.rs:1685`, `lib.rs:1720`, `lib.rs:2588`, `lib.rs:2602`	Unreachable path

Both instructions require a signature of `token_state.authority`. On mainnet the authority is the SPL multisig account `5D2kznd22qoYNnaFxCxPvaTfHMAfQ8YTjdA1iGCSpHVz`, which cannot sign a transaction. Fee changes go through `execute_update_purchase_fee_proposal`. `set_purchase_fee` also has no pause check and no reentrancy guard.

I-03 `update_reserve_value` cannot succeed

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Reserve backing	`lib.rs:2197–2240`	Unreachable path

`update_reserve_value` requires `backing_config.enabled`. No code path sets it: `configure_backing` returns `FunctionDeprecated` and no proposal type enables backing. On mainnet the flag is false and `reserve_value` is 0.

I-04 Metadata decimals argument and URI

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Token metadata	`lib.rs:2001`	Data

`create_token_metadata` passes `decimals: Some(9)` while the mint has 6. The mint already exists, so the value is not stored and wallets read 6 from the mint. The metadata URI on mainnet is `https://dremt.io/logo.png`, an image, where the Metaplex standard expects a JSON document with the image link inside.

I-05 Burn counter and internal supply differ from the chain

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Accounting	`state.rs:312`, `lib.rs:1213–1220`	Counters

`security_metrics.total_burned` is never written and reads 0. `token_state.total_supply` reads 10,002,384.906089 against a mint supply of 10,002,384.876703, a difference of 0.029386 DREMT. The `max_supply` check uses the internal counter.

I-06 The mainnet binary is not a reproducible build

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Deployment	Program `4iwHwvSXrdpgsVPhrM4XDB9Lh7s284MJFJToeS9N8GJh`	Build verification

The deployed binary and the local build of the source differ in bytes, and no verifiable build is registered. The identity of code and binary rests on the symbol comparison in section 06. A verifiable build of the deployed source lets any third party confirm it.

06 Deployment verification

ITEM	READ ON CHAIN, 2 NOVEMBER 2026	SOURCE OR LOCAL BUILD	RESULT
Program id	`4iwHwvSXrdpgsVPhrM4XDB9Lh7s284MJFJToeS9N8GJh`	`declare_id!` at `lib.rs:29`	Match
Upgrade authority	`DiRfgcJivBsawk11SDD1YpUcqW7YAT8Ai7YbxB6osTVd`	PDA of seed `upgrade_authority`	Match
Last deploy slot	402,494,650, 24 February 2026	`lib.rs` dated 24 February 2026	Same day
Program length, bytes	974,704	972,920	Different build
Executable hash	`64a55ea9...9f743`	`72dc7191...7e392`	Different build, I-06
Instruction names	34 of 34 present	34 in the interface	Match
Error texts	103 of 103 present	103 in `error.rs`	Match

CHECK	RESULT
Mint	Owner Token-2022, 82 bytes, 6 decimals, mint and freeze authority `E5rNU7YXJCzyEcWZFKANUV9Uf29GuujNgjNdnEtdwu6m`
Multisig	SPL Token multisig, 3 required of 5 valid signers, initialized
USDC pin	The USDC vault holds mint `EPjFWdd5AufqSSqeM2qN1xzybapC8G4wEGGkZwyTDt1v`; 62 `mint_by_user` calls paid into it
Supply against payments	2,384.906089 DREMT bought times 0.80 equals 1,907.92 USDC; the vault holds 1,907.924878 USDC
Conclusion	Program id, authority, deploy date, every instruction and every error text match the reviewed source. A byte match was not possible, see I-06

07 Testing

RUN	TESTS	PASSED	FAILED
Client unit tests, program crate	111	111	0
Demonstration tests added in this review, `state.rs` (L-01, L-02)	2	2	0
Fork demonstration on a local validator (M-01, M-03, L-06)	5	5	0

TOPIC	OBSERVATION
Covered	Vesting schedule validation, TGE and cliff arithmetic, timestamp bounds, large allocations, proposal threshold, blacklist search, CPI flag logic
Not covered	By the client suite: blacklist and pause against transfers (M-01), refund destination of a burn (M-03), mint mutability in a burn (L-06), resume with a zero `max_pause_duration` (L-01), pause counter after a resume (L-02). All six are shown by the tests and fork runs added in this review
Dependencies	275 crates, 0 vulnerabilities; 7 warnings for unmaintained or unsound crates (`bincode`, `libsecp256k1`, `anyhow`, `keccak`, `rand`)

08 Review coverage

AREA	CHECKED	RESULT
Purchase	Price, fee, limits per transaction and per address, USDC pin, supply cap	L-03
Multisig proposals	Threshold, duplicate approvals, expiry, cancel, signer set of the SPL multisig, executor rights	M-03, L-05, L-06
Vesting	TGE, cliff, linear release, pause, resume, counters, config bounds	L-01, L-02, L-04
Blacklist and pause	Coverage of transfers, size limit, protected system addresses	M-01
Metadata	Signer checks, Metaplex call, on-chain metadata	M-02, I-04
Authority and upgrade	Upgrade authority, `transfer_authority`, `set_purchase_fee`	I-02
Arithmetic	Checked operations, refund overflow bound, rounding of the USDC amount	No issue found
Accounts and seeds	PDA seeds and bumps, mint and vault constraints, token program checks	No issue found
Reentrancy	Operation guard, account locks within a transaction	No issue found
Dead and unreachable code	CPI module, backing and oracle paths	I-01, I-03
Accounting	Supply counters against the mint and the vaults	I-05
Deployment	Program id, authority, slot, binary comparison	I-06

09 Disclaimer

This report was prepared by SOKEN LTD (Companies House 15253906). It records a security review of the source code at commit bdc99fb889b6 and of the program deployed on Solana mainnet, dated 2 November 2026. A security review is a point-in-time assessment of the code in scope and is not a guarantee that the code is free of defects, nor an endorsement of the project, its economics or its operators. Statements about on-chain configuration describe the state on the date of reading; on-chain values change, so re-read any figure at the linked address before relying on it. Off-chain key management, operational practice, the front end and third-party protocol risk are outside the scope of this review. Nothing in this document is financial, investment or legal advice.